

SYSTEM CAPABILITY & ARCHITECTURAL BRIEF

Shopify Revenue Assurance Auditor

Senior Shopify Architect audit engine detecting silent revenue leaks, shipping coverage gaps, discount margin stacking exploits, and pixel collisions from raw Admin GraphQL payloads.

COMPLIANCE SPEC: Shopify Admin GraphQL API 2024-10 | SECURITY MODEL: Zero-Exfiltration Client Analysis | DOC VERSION: 2.4.0

[1] 1. Executive Overview & Purpose

High-growth Shopify Plus and enterprise merchants frequently suffer silent profit erosion due to complex combinations of shipping tier gaps, unrestricted discount stacking rules, and uncoordinated marketing scripts. Standard Shopify Admin interfaces display each setting in isolation, making compound vulnerabilities invisible until merchants reconcile monthly margins.

The Shopify Revenue Assurance Auditor provides an automated, deterministic audit framework that ingests the raw Shopify Admin GraphQL configuration graph and performs cross-domain rule evaluations, margin risk simulations, and produces immediate, copy-pasteable remediation mutations.

[2] 2. Core Architectural Pillars

A. Deterministic Multi-Domain Auditing

Comprehensive rule validation spanning delivery profiles, combinable discount logic, web pixel events, and theme scripts without requiring external store credentials or destructive mutations.

B. Worst-Case Margin Erosion Simulation

Permutational cart calculator analyzing stacking rules against standard basket sizes (\$25 to \$500), specifically isolating catastrophic \$0 checkout exploits and merchant-absorbed shipping fees.

C. Production-Ready Remediation Mutations

Direct Shopify Admin navigation paths coupled with copy-pasteable GraphQL mutation payloads that engineering teams or agencies can execute directly via GraphiQL to resolve each finding.

D. Executive Reporting & Stakeholder Dispatch

Standardized JSON reporting format suitable for CI/CD audit pipelines, paired with on-demand executive email summaries and historical change tracking for enterprise compliance.

[3] 3. Detailed Audit Domain Engines

The audit engine inspects the complete merchant configuration graph across three specialized domains:

Domain 1: Delivery & Shipping Profile Architecture

- **Orphaned Active Selling Markets:** Detects markets enabled for commerce where no delivery profile zone or rate is configured. Customers from these countries can browse products and add to cart, but encounter a hard checkout error ("This order cannot be shipped to your location"), creating high cart abandonment.
- **Weight & Price Tier Discontinuities:** Identifies gaps between tiered rates (e.g. Rate A covers 0-5.0 lbs; Rate B covers 5.1-10.0 lbs, leaving orders weighing 5.01-5.09 lbs with zero available rates at checkout).
- **Uncapped Tier Thresholds & Margin Subsidies:** Flags price-based tiers with hard upper subtotal caps (e.g. max \$150) that lock out high-value orders, or shipping rates priced significantly below typical freight costs without minimum order thresholds.
- **Multi-Location Fulfillment Gaps:** Audits active fulfillment centers against profile location groups to prevent backorder lockups or inventory routing mismatches.

Domain 2: Discounts, Promotions & Margin Protection

- **Unrestricted Three-Way Stacking:** Flags discount combinations where order-level, product-level, and shipping discounts are all allowed to stack simultaneously, bypassing intended promotional boundaries.
- **Zero-Dollar (\$0) Cart Exploit Risk:** Discovers vulnerabilities where cumulative percentage and fixed-amount codes reduce cart subtotals and shipping fees to \$0.00, enabling malicious exploiters or coupon scrapers to clear inventory at zero cost.
- **Uncapped High-Percentage Codes:** Audits percentage discounts exceeding 30% that lack maximum discount limits or subtotal requirements, exposing luxury or high-cost catalog items to severe margin erosion.
- **Orphaned & Infinite Usage Codes:** Flags active promotional codes with missing expiration dates and unlimited customer usage limits that remain active indefinitely.

Domain 3: Tracking Infrastructure & Pixel Collisions

- **Dual-Pixel Tracking Collisions:** Detects duplicate event firing between the modern sandboxed Shopify Web Pixels API and legacy REST ScriptTags or inline theme scripts (Meta Pixel, Google Tag Manager / GA4, TikTok, Pinterest). Eliminates inflated conversion counts, duplicated revenue in ad managers, and wasted ad spend.
- **Deprecated REST ScriptTags:** Flags legacy third-party script tags that inject unvetted JavaScript into storefronts and checkouts, causing performance degradation, security liabilities, and checkout latency.
- **Checkout Extensibility Compliance:** Highlights hardcoded script tags and deprecated checkout.liquid references requiring migration to Shopify Checkout Extensibility and Web Pixels.

[4] 4. Application Feature Deep-Dive

A. Raw GraphQL Ingest & Master Query Tooling

- **Flexible Data Ingestion:** Accepts raw JSON payloads directly from Shopify Admin API or GraphiQL app. Automatically handles nested envelopes ({ data: ... }, { edges: [...] }, { nodes: [...] }) or flat arrays.
- **Interactive GraphQL Query Modal:** Built-in modal containing the production-ready GraphQL query designed to fetch all required delivery, discount, market, location, pixel, and script tag entities in a single batch.
- **Pre-Packaged Enterprise Benchmark Cases:** Four real-world production test cases for instant verification: (1) Enterprise Apparel Multi-Domain Risk, (2) DTC Beauty Zero-Dollar Cart, (3) Global Luxury Orphaned Markets, and (4) Clean & Optimized Merchant Baseline.

B. Executive Dashboard & Risk Indexing

- **Composite Store Risk Score (0-100):** Weighted scoring algorithm assessing severity distribution (Critical, High, Medium, Low) and financial exposure, categorizing stores into CRITICAL RISK, HIGH RISK, ELEVATED, or HEALTHY.
- **Critical Metric Badges:** Immediate visual status indicators for Zero-Dollar Cart vulnerability, Max Stackable Discount %, and Affected Node counts.
- **Interactive Cross-Filtering:** Filter findings seamlessly by domain (Delivery, Discounts, Tracking) or severity level.

C. Worst-Case Margin Simulator

- **Order Basket Stress Testing:** Simulates 5 representative shopping cart sizes (\$25, \$50, \$100, \$250, \$500) under maximum stackable discount conditions.
- **Financial Breakdown Table:** Itemizes Gross Revenue, Product Discounts, Order Discounts, Merchant-Absorbed Shipping, and Net Merchant Revenue for each basket size.
- **Margin Erosion Percentage:** Visualizes the exact percentage of top-line revenue eliminated by overlapping policies.

D. Remediation Playbook & Workflow Management

- **Step-by-Step Guidance:** Clear instructions and admin navigation paths (e.g., Shopify Admin -> Settings -> Shipping) for non-technical store managers.
- **Copy-Paste GraphQL Mutations:** Syntax-highlighted mutation snippets (with exact IDs and arguments) for developers to execute directly via GraphQL.
- **Audit Workflow Tracking:** State management allowing engineers to mark issues as OPEN, IN_PROGRESS, RESOLVED, or IGNORED with custom remediation notes.

[5] 5. Collaboration, Exports & Compliance

- A. Structured JSON Audit Report & Diff Tracking
- **Standardized Audit Schema:** Converts findings, worst-case exposure metrics, and inspected node tallies into an industry-standard JSON schema for automated auditing.
 - **One-Click JSON Export:** Instant download and clipboard copy functions for storing audit reports in git repositories or compliance archives.
 - **Audit Comparison & Diff Engine:** Tracks sequential audit runs against the same store, highlighting newly introduced configuration vulnerabilities, resolved issues, and risk score deltas.
- B. Executive Email Issues Recap Dispatch
- **Client Stakeholder Summaries:** Generates executive-ready email recaps highlighting overall risk, margin vulnerability, and itemized issues with severity tags and financial impact snippets.
 - **Backend Dispatch & Archive (/api/send-recap):** Server endpoint with email validation, dispatch logging, and an audit trail archive of dispatched recaps accessible via /api/recaps.
 - **One-Click Plaintext Clipboard Copy:** Copies human-readable executive audit summaries formatted for direct pasting into Slack, Notion, or Jira tickets.
- C. Feedback & Anti-Spam Architecture
- **In-App Bug Reporting & Feedback Modal:** Built-in submission modal capturing bug reports, feature suggestions, and rule enhancement requests with attached store context.
 - **IP-Based Anti-Spam Rate Limiter:** Enforces a 5-minute cooldown window per client IP on the Express backend (/api/feedback), with real-time countdown timer integration (/api/feedback/status).

[6] 6. Technical Specifications & Stack Summary

SYSTEM COMPONENT	TECHNOLOGY / PATTERN	RESPONSIBILITY / GUARANTEE
Frontend Framework	React 19 + TypeScript + Vite 6	High-performance interactive SPA with dark/light themes
Audit Computation	Pure TypeScript In-Memory Engine	100% deterministic, zero exfiltration of store data
Backend Server	Express 5 (Node.js runtime)	REST APIs for feedback, recaps, and static serving
Styling & Design	Tailwind CSS v4 + Lucide Icons	Responsive, high-density professional architectural UI
API Standard	Shopify Admin GraphQL 2024-10	Aligned with latest Shopify Checkout Extensibility standards
State & Diff Engine	React Context + Local Storage	Seamless session persistence and historical audit diffing

Document prepared for technical review and evaluation. Generated as a standalone feature specification overview.

